Modelo de confiança entre PC, celular e relógio

Este documento descreve o que o código atual oferece para os clientes móveis e o que ainda falta para um modelo de menor privilégio por dispositivo. Ele foi conferido por inspeção estática do main em 14 de outubro de 2026. Isso não substitui um teste em aparelhos reais.

Resumo

- O pareamento exige um código temporário iniciado no PC, uma chave privada gerada pelo cliente e uma prova de posse dessa chave.
- O computador mantém a chave pública, o nome informado pelo cliente e o estado de autorização no banco local ~/.config/vladmir/mobile-devices.db. O arquivo e o diretório são criados com permissões restritas ao usuário.
- O dono aprova ou revoga cada identidade no painel Celular e segurança do desktop.
- As sessões são temporárias, vinculadas à identidade do dispositivo e invalidadas por revogação, lockdown e reinício do servidor.
- Limitação atual: a autorização é ampla por dispositivo. O servidor não mantém concessões separadas para celular e relógio nem escopos independentes para agenda, histórico, chat, voz, telemetria, biblioteca ou ferramentas de programação.
- Portanto, parear o relógio não o limita hoje a lembretes. Também não se deve interpretar "proprietário" como um papel de permissões detalhadas: os clientes autenticados por dispositivo têm algumas ações críticas bloqueadas, mas várias rotas compartilham a mesma autorização.

Fluxo implementado

1. No Vladmir Desktop, o operador abre o pareamento por até cinco minutos. Um novo código substitui o anterior e o lockdown impede abrir pareamento.
2. O cliente cria sua identidade criptográfica local e envia nome, chave pública, código e assinatura de prova de posse. O código é de uso único e expira.
3. O PC cadastra a identidade como pending; isso ainda não concede acesso autenticado às rotas protegidas.
4. O operador confere o dispositivo na lista e aprova ou revoga manualmente. O servidor identifica o dispositivo pelo hash da chave pública, não pelo nome exibido.
5. O dispositivo autorizado abre uma sessão assinada. O token de sessão é aleatório, fica apenas em memória do servidor, dura cinco minutos por padrão e é vinculado ao dispositivo e à geração de segurança vigente.
6. As requisições autenticadas incluem assinatura do método, caminho, hash do corpo, horário, nonce, identificador da requisição e hash do token. O servidor rejeita assinatura inválida, horário fora da janela, nonce repetido, sessão expirada, dispositivo não autorizado ou lockdown ativo.

O protocolo protege contra reutilização de requisição e vincula a credencial ao dispositivo. A segurança da conexão também depende de transporte protegido quando o acesso sai do loopback: configure TLS ou um túnel autenticado e não exponha a API diretamente à internet.

Dados armazenados

Local	Dados identificados no código	Observação
PC: ~/.config/vladmir/mobile-devices.db	ID derivado da chave pública, nome informado no pareamento, chave pública, estado (pending, authorized, revoked), data de cadastro, nonces recentes e configurações de segurança	Não guarda a chave privada do celular/relógio nem os tokens efêmeros de sessão. O banco usa SQLite/WAL; as permissões de arquivo e diretório são restringidas ao usuário local.
Cliente Android/Wear	A implementação de autenticação do servidor prova posse de uma chave privada, mas este documento não confirma os detalhes do armazenamento ou a proteção contra backup em cada cliente	Tratar armazenamento e migração da chave nos APKs como pendência de auditoria específica do cliente.

Servidor em execução | Tokens de sessão em memória, por até cinco minutos | Reiniciar o processo limpa as sessões.
Memória da conversa | Mensagens podem ser compartilhadas pela memória do servidor, dependendo do fluxo de chat | Pareamento não isola conversas por dispositivo. Evite enviar conteúdo que não queira compartilhar com clientes conectados.

O documento não afirma que todos os dados auxiliares de Android/Wear ficam exclusivamente no dispositivo; os detalhes devem ser confirmados em código e em cada versão publicada antes de uma promessa de produto.

Revogar aparelho perdido ou não reconhecido

1. No PC, abra Celular e segurança • Vladmir.
2. Atualize a lista, selecione o nome/identificador correspondente e confira o dispositivo antes de agir.
3. Use Revogar e confirme.
4. A revogação avança a geração de segurança; as sessões anteriores daquele cadastro deixam de ser aceitas. Se o dispositivo voltar a ser confiável, faça novo pareamento e aprovação.
5. Para bloquear temporariamente todos os dispositivos móveis, use lockdown quando disponível na interface. Lockdown rejeita autenticação e impede novo pareamento enquanto ativo.

Se o PC foi perdido ou comprometido, revogar a partir de outro dispositivo não é possível: proteja a conta do sistema operacional e a cópia de segurança local do banco. A API não oferece uma conta central remota para recuperação.

Matriz do que está autorizado hoje

Recurso | Estado no servidor atual
Saúde, modelos e agenda | Compartilham a autorização geral do cliente autenticado.
Histórico | Compartilhado; o endpoint não aplica filtro por dispositivo.
Chat e chamada/voz | Disponíveis a clientes autorizados; as conversas entram na memória compartilhada.
Telemetria Wear | Endpoint específico, mas ainda submetido à mesma identidade autorizada; isso não equivale a um escopo ACL.
Limpar memória e desligar | Requisições de cliente por dispositivo são bloqueadas e exigem confirmação no PC.
Biblioteca de conhecimento | Não há escopo por dispositivo neste modelo de autenticação. Acesso por outros fluxos deve ser revisado separadamente.
Ferramentas de programação/edição | Este mecanismo não concede um papel isolado de ferramenta ao relógio; também não oferece um deny explícito granular por dispositivo em todas as operações. Não trate o pareamento como uma fronteira completa de autorização.

Lacunas e plano de melhoria

1. Adicionar perfis e escopos explícitos por identidade, com privilégio mínimo por padrão (por exemplo: relógio com lembretes e estado; celular com chat/voz; PC como administrador).
2. Separar permissões de leitura e escrita para agenda, histórico, biblioteca, câmera, microfone, voz, anexos e ferramentas de programação.
3. Fazer o servidor validar cada escopo em cada rota e operação; esconder um botão no cliente não é controle de segurança.
4. Criar interface no PC para consultar e alterar escopos por aparelho, mostrando o efeito, a data e o estado.
5. Definir política de retenção e isolamento da memória compartilhada, com opção de não gravar chats do relógio/celular e apagar dados por dispositivo quando possível.
6. Auditar clientes Android/Wear: geração e armazenamento da chave, backup, migração, exportação de diagnósticos, dados locais e comportamento ao desinstalar.
7. Cobrir autorização com testes negativos: relógio sem escopo não lê bibli

oteca, não chama ferramentas, não acessa anexos e não altera agenda; revoga
ção corta sessão ativa; escopos não aumentam após reconexão.
8. Documentar os passos de recuperação para roubo/perda, inclusive o caso e
m que o PC está indisponível.

Até essas etapas serem implementadas e testadas, o modelo deve ser descrito
como pareamento criptográfico e revogação por dispositivo com autorização
ampla, não como permissões completas por recurso.

Evidências no código

- src/mark/device_auth.py: código de pareamento, validação de prova de poss
e, registro local, sessões, lockdown e revogação.
- src/mark/mobile_api.py: autenticação de requisições e rotas móveis/Wear.
- src/mark/desktop.py: diálogo de gestão, aprovação e revogação de disposit
ivos.
- tests/test_device_auth.py: cobertura de aprovação, assinatura/replay, loc
kdown, expiração, sessão vinculada e revogação. Esses testes exercitam o ba
ckend; não comprovam armazenamento seguro no APK nem comportamento físico d
e Android/Wear.